

FARMACIA VANNESA — SISTEMA DE GESTIÓN FARMACÉUTICA

PLAN DE AUDITORÍA INFORMÁTICA DE CALIDAD DE SISTEMAS

Programa de Trabajo Detallado de 25 Auditorías del Ciclo de Vida del Software (SDLC)
Tarea: Plan de sistemas realizados

Organización / Cliente:	Farmacia Vannesa (Comercializadora de Productos Farmacéuticos)
Sistema Evaluado:	Sistema Web de Control Farmacéutico e Inventarios (Farmacia Vannesa - SDLC)
Tipo de Auditoría:	Auditoría Informática de Calidad, Estándares de Ingeniería y Gobernanza SDLC
Alcance Metodológico:	5 Fases del Ciclo de Vida (25 Auditorías Técnicas con Procedimientos en 2 Pasos)
Equipo Desarrollador Auditado:	Marvin Castañeda, Claudio Arana, Edwin Sevilla, Jester Mendieta
Fecha / Versión:	Octubre 2026 Versión 1.0 (Documento Oficial de Planificación)

■ **ENFOQUE EXCLUSIVO EN CALIDAD Y GOBERNANZA:** El presente plan evalúa las cinco (5) fases del ciclo de vida del software (SDLC): Requerimientos, Diseño, Construcción, Pruebas y Despliegue, totalizando 25 auditorías operativas. Se excluyen deliberadamente auditorías de infraestructura física (servidores on-premise, racks, UPS físicos de centros de cómputo) y redes Wi-Fi perimetrales, concentrando el rigor en la ingeniería de software y estándares ISO/IEC 25010, IEEE 830 y CMMI-DEV.

1. Gobernanza de Calidad del Desarrollo del Sistema

La Gobernanza de Calidad establece las directrices organizacionales, responsabilidades, canales de comunicación y políticas técnicas para asegurar que el sistema satisfaga los estándares internacionales. Comprende la estructura metodológica bajo la cual el equipo concibe, construye, verifica y despliega el producto.

- **Estructura de Roles SQA:** Segregación formal de funciones entre Product Owner (reglas de negocio), Líder de Arquitectura (Clean Architecture), QA Lead (cobertura Pytest >= 80% y DoD), Desarrolladores (PEP 8 y TDD) e Ingeniero DevOps (configuración segura .env y rollback).
- **Canales y Telemetría:** Standups diarios de 15 minutos, bitácora inmutable de defectos y registro estructurado de eventos en 'logs/farmacia_vannesa.log' con rotación automática (RotatingFileHandler de 5 MB) y formato ISO 8601.
- **Definition of Done (DoD):** Todo cambio debe tener 100% de tests unitarios aprobados, cobertura >= 80% y validación de linters PEP 8 sin advertencias bloqueantes.

2. Objetivos de la Auditoría de Calidad

Objetivo General: Evaluar de forma objetiva, sistemática y rigurosa la efectividad, seguridad, calidad y alineación de los controles de TI en el Sistema Web de Farmacia Vannesa, garantizando confidencialidad, integridad y disponibilidad, así como el cumplimiento de los estándares de calidad en las 5 fases del SDLC.

Objetivos Específicos: Validar requerimientos atómicos y checklist IEEE 830; auditar modelo de datos relacional con los 11 campos mandatorios y Clean Architecture; verificar cumplimiento PEP 8 y seguridad estática OWASP; comprobar cobertura Pytest >= 80% y pruebas de valores límite; y auditar endpoint de monitoreo /health y plan de rollback < 15 min.

3. Alcance, Exclusiones y Marcos de Referencia

Alcance: Cubre el 100% del ciclo de vida del software: requerimientos SRS, modelo de datos relacional, código fuente Flask/Python, pruebas Pytest, scripts de respaldo/rollback y configuración de despliegue.

Exclusiones: Servidores físicos on-premise, racks, UPS físicos de centros de cómputo, cableado estructurado y redes Wi-Fi de visitas.

Estándar / Marco	Ámbito de Aplicación	Criterios Clave Evaluados
ISO 19011:2018	Metodología de Auditoría	Principios de auditoría, enfoque basado en riesgos, evidencia objetiva y formalidad.
ISO/IEC 25010:2011	Modelo de Calidad Software	Adecuación funcional, fiabilidad, mantenibilidad, modularidad y seguridad.
IEEE 830 / ISO 29148	Ingeniería de Requerimientos	Checklist de 8 características: Correcto, No ambiguo, Completo, Consistente, Verificable, etc.
CMMI-DEV v2.0	Madurez de Procesos SDLC	Áreas: Planificación, Calidad de Proceso y Producto (PPQA), Verificación y Validación.

OWASP Top 10 & PEP 8	Construcción y Seguridad	Mitigación de Inyección SQL, XSS, contraseñas seguras y guía de estilo Python.
----------------------	--------------------------	--

4. Matriz de Evaluación de Riesgos de Calidad (Metodología 1 a 3)

La escala evalúa Probabilidad (1 a 3) e Impacto (1 a 3): Nivel de Severidad = P × I (1-2 Bajo, 3-4 Medio, 6-9 Alto/Crítico).

ID	Descripción del Riesgo de Calidad	P	I	R. Inh.	Controles Existentes	R. Res.	Estrategia / Plan de Acción
R-CAL-01	Ambigüedad en requerimientos causa fallas en stock e inventario.	3	3	9 (Alto)	Revisiones informales.	2x2=4	Mitigar: Checklist IEEE 830 y atómicos.
R-CAL-02	Acoplamiento en Flask impide tests y escalabilidad.	3	2	6 (Alto)	Uso parcial de módulos.	2x1=2	Mitigar: Clean Architecture estricta.
R-CAL-03	Deuda técnica y no apego a PEP 8 eleva fallos y costos.	2	2	4 (Med)	Revisión visual ocasional.	1x2=2	Mitigar: Linters Flake8 y escaneo SAST.
R-CAL-04	Baja cobertura de tests en ventas causa sobreventas.	3	3	9 (Alto)	Testing manual básico.	1x2=2	Mitigar: Pytest >= 80% y valores límite.
R-CAL-05	Despliegues manuales y fallas en migraciones de BD.	2	3	6 (Alto)	Respaldo manual ocasional.	1x2=2	Mitigar: backup_db.py (Rollback < 15 min).

5. Programa de Trabajo Detallado (25 Auditorías en 2 Pasos)

A continuación se especifican las 25 auditorías técnicas del SDLC con procedimiento en dos pasos operativos:

Módulo 1: Fase de Análisis de Requerimientos (5 Auditorías)

Auditoría A-01: Revisión de Atomicidad de Requerimientos			
Objetivo:	Verificar que cada requerimiento funcional describa una única funcionalidad.		
Paso 1 (Ejecución):	Seleccionar al azar 5 requerimientos de la especificación SRS. Analizar que no mezclen responsabilidades operativas disjuntas.		
Paso 2 (Verificación):	Documentar la matriz de atomicidad con la justificación individual y propuesta de descomposición.		
Criterio Aceptación:	100% de los requerimientos auditados debe describir una única necesidad funcional comprobable.		
Evidencia / Papel:	Matriz de evaluación de atomicidad Estándar: ISO/IEC/IEEE 29148:2018 (Cláusula 5.2.5)		
Requerimiento Muestreado	Descripción Original	Evaluación de Atomicidad	Dictamen y Ajuste Requerido
RF01: Autenticación y Perfiles	Inicio de sesión seguro con contraseña encriptada, asignando roles (Admin, Farmacéutico, Vendedor) y restringiendo accesos.	Parcialmente Atómico. Agrupa autenticación, almacenamiento seguro (hashing) y autorización RBAC en un solo texto.	Dividir en: RF01.1 (Autenticación), RF01.2 (Hashing seguro bcrypt), RF01.3 (Control RBAC).
RF03: Catalogación con 11 Campos	Registrar medicamentos con código de barra, principio activo, concentración, laboratorio, lote, vencimiento, costo, precio, stock.	No Atómico. Mezcla el catálogo maestro del producto con la gestión de existencias físicas por lote.	Desacoplar en: RF03.1 (Catálogo maestro 11 campos) y RF03.2 (Existencias por lote/vencimiento).
RF06: Módulo de Ventas y Bloqueo	Procesar ventas en carrito, calcular subtotales e impuestos, y bloquear ventas si exceden el stock físico.	No Atómico. Une cálculo comercial de venta con la regla crítica de bloqueo y reserva concurrente de stock.	Separar en: RF06.1 (Cálculo y ticket de venta) y RF06.2 (Validación concurrente atómica de stock).
RF09: Inventario y Kardex	Actualizar inventario en tiempo real con entradas por compras, salidas por ventas, mermas y ajustes manuales.	Parcialmente Atómico. Agrupa movimientos automáticos con ajustes manuales que requieren permisos distintos.	Dividir en: RF09.1 (Kardex transaccional automático) y RF09.2 (Ajustes manuales y mermas por Admin).
RF12: Alertas de Stock Crítico	Emitir alertas en panel si un fármaco tiene menos de 10 unidades o vence en 30 días.	No Atómico y Rígido. Une stock mínimo con proximidad de vencimiento y usa umbrales 'quemados'.	Ajustar a umbrales dinámicos: RF12.1 (Alerta stock < stock_minimo) y RF12.2 (Alerta por caducidad).
Auditoría A-02: Revisión de Claridad y Definición			
Objetivo:	Verificar que los requerimientos carezcan de ambigüedades.		
Paso 1 (Ejecución):	Inspeccionar términos vagos ('rápido', 'adecuado'). Confirmar redacción técnica adecuada.		
Paso 2 (Verificación):	Elaborar informe técnico con observaciones semánticas y recomendaciones.		
Criterio Aceptación:	100% de los requerimientos debe carecer de ambigüedades.		

Evidencia / Papel:	Matriz de claridad léxica Estándar: IEEE 830 (No Ambigüedad)
Auditoría A-03: Revisión de Verificabilidad	
Objetivo:	Verificar que cada requerimiento pueda validarse mediante un caso de prueba.
Paso 1 (Ejecución):	Evaluar la testabilidad de cada requerimiento funcional frente a aserciones en Pytest.
Paso 2 (Verificación):	Generar ficha técnica vinculando el requerimiento con su correspondiente test automatizado.
Criterio Aceptación:	100% de los requerimientos debe ser verificable mediante pruebas computables.
Evidencia / Papel:	Ficha técnica de verificabilidad Estándar: IEEE 830
Auditoría A-04: Revisión de Trazabilidad Bidireccional	
Objetivo:	Verificar la correspondencia bidireccional entre requerimientos, código y tests.
Paso 1 (Ejecución):	Revisar matriz RTM completa. Verificar que cada requerimiento tenga caso de uso, repositorio y test.
Paso 2 (Verificación):	Documentar matriz RTM consolidada y porcentaje de cobertura de trazabilidad.
Criterio Aceptación:	0% de requerimientos huérfanos y cobertura de trazabilidad $\geq$ 95%.
Evidencia / Papel:	Matriz RTM bidireccional Estándar: CMMI-DEV v2.0 (REQM)
Auditoría A-05: Cumplimiento de Normas IEEE 830	
Objetivo:	Evaluar la especificación frente a las 8 características mandatorias de calidad.
Paso 1 (Ejecución):	Aplicar checklist formal: Correcto, No ambiguo, Completo, Consistente, Clasificado, Verificable, Modificable, Trazable.
Paso 2 (Verificación):	Emitir lista de chequeo formal firmada con el porcentaje de conformidad obtenido.
Criterio Aceptación:	Cumplimiento $\geq$ 90% en las 8 características del estándar IEEE 830.
Evidencia / Papel:	Checklist formal IEEE 830 Estándar: IEEE 830:1998

Módulo 2: Fase de Diseño de Software (5 Auditorías)

Auditoría A-06: Revisión del Modelo de Datos (11 Campos y 3FN)	
Objetivo:	Verificar que el modelo de productos contemple los 11 campos mandatorios y normalización 3FN.
Paso 1 (Ejecución):	Inspeccionar DDL de tabla products: name, generic_name, product_code, description, stock, presentation, laboratory, expiration_date, dose, cost_price y sale_price.
Paso 2 (Verificación):	Verificar índice UNIQUE idx_products_code, triggers de cantidad positiva y Foreign Keys.
Criterio Aceptación:	100% de los 11 campos presentes con tipos adecuados (DECIMAL, DATE, INT).
Evidencia / Papel:	Script DDL auditado y diccionario de datos Estándar: Normalización 3FN
Auditoría A-07: Revisión de la Arquitectura de Seguridad	
Objetivo:	Verificar que la autenticación aplique funciones de hashing robustas y protección de rutas.
Paso 1 (Ejecución):	Revisar auth_service.py y verificar hash + salt con Werkzeug (scrypt/pbkdf2). Confirmar middleware de rutas.
Paso 2 (Verificación):	Capturar la estructura de almacenamiento seguro de contraseñas y decoradores.
Criterio Aceptación:	100% de contraseñas con hash robusto y 0 rutas administrativas expuestas.
Evidencia / Papel:	Captura hash BD y código de decoradores Estándar: OWASP ASVS
Auditoría A-08: Revisión del Diseño de Integración Dual	
Objetivo:	Verificar que la integración dual (Supabase Cloud y SQLite local) opere con transacciones atómicas.
Paso 1 (Ejecución):	Examinar inyección de dependencias en main.py y conmutación transparente ante caída de red.
Paso 2 (Verificación):	Documentar flujo de conmutación resiliente y consistencia transaccional ACID.
Criterio Aceptación:	Persistencia transparente con soporte de transacciones ACID en ambos motores.
Evidencia / Papel:	Diagrama de integración y prueba de conmutación Estándar: Resiliencia BCP
Auditoría A-09: Revisión del Diseño de Interfaz de Usuario (UI/UX)	
Objetivo:	Evaluar ergonomía y velocidad operativa de despacho en mostrador farmacéutico (POS).
Paso 1 (Ejecución):	Inspeccionar sales.html e inventory.html. Medir clics para buscar por código de barra y totalizar venta.
Paso 2 (Verificación):	Verificar alertas visuales destacadas para productos con bajo stock (< 10) y próximos a vencer.
Criterio Aceptación:	Operación de venta ágil en mostrador con alertas visibles de stock crítico.
Evidencia / Papel:	Evaluación heurística de usabilidad POS Estándar: ISO 9241-11
Auditoría A-10: Revisión del Diseño de Escalabilidad y Concurrencia	
Objetivo:	Verificar que el diseño soporte al menos 50 usuarios concurrentes sin quiebres de inventario.
Paso 1 (Ejecución):	Analizar uso de índices DDL ('idx_products_code') y validación atómica previa al descuento de stock.
Paso 2 (Verificación):	Documentar análisis de contención y aislamiento transaccional para operaciones concurrentes.

Criterio Aceptación:	Soporte para >= 50 usuarios concurrentes sin condiciones de carrera.
Evidencia / Papel:	Reporte de diseño de escalabilidad Estándar: ISO/IEC 25010

Módulo 3: Fase de Construcción de Software (5 Auditorías)

Auditoría A-11: Revisión de Calidad del Código y Complejidad	
Objetivo:	Verificar código libre de vulnerabilidades críticas y complejidad ciclomática controlada.
Paso 1 (Ejecución):	Ejecutar Flake8 y Radon sobre todo el código en 'app/'. Identificar code smells y funciones complejas.
Paso 2 (Verificación):	Documentar matriz de complejidad asegurando que ninguna función exceda un valor de 10.
Criterio Aceptación:	Complejidad ciclomática < 10 en todas las funciones y 0 defectos críticos.
Evidencia / Papel:	Reporte Flake8 y reporte de complejidad Radon Estándar: McCabe
Auditoría A-12: Revisión de Cobertura de Pruebas Unitarias	
Objetivo:	Verificar que la cobertura de pruebas automatizadas en la lógica de negocio sea >= 80%.
Paso 1 (Ejecución):	Ejecutar suite con 'pytest --cov=app/application/services --cov=app/domain'. Medir líneas cubiertas.
Paso 2 (Verificación):	Generar reporte Coverage.py demostrando el cumplimiento del umbral del Definition of Done.
Criterio Aceptación:	Cobertura >= 80% (Verificado en proyecto: 84% de cobertura alcanzada).
Evidencia / Papel:	Reporte Coverage.py con 84% alcanzado Estándar: IEEE 1008-1987
Auditoría A-13: Revisión de Codificación Segura (OWASP Top 10)	
Objetivo:	Verificar mitigación de inyección SQL, XSS, CSRF y exposición de datos.
Paso 1 (Ejecución):	Ejecutar escaneo estático SAST con Bandit. Comprobar queries parametrizadas y tokens CSRF.
Paso 2 (Verificación):	Emitir reporte ejecutivo de hallazgos SAST categorizados por nivel de severidad.
Criterio Aceptación:	0 vulnerabilidades de inyección SQL y 0 vulnerabilidades de severidad alta.
Evidencia / Papel:	Reporte SAST generado con Bandit Estándar: OWASP Top 10
Auditoría A-14: Revisión de Gestión de Dependencias y CVEs	
Objetivo:	Verificar que las librerías en requirements.txt estén fijadas y libres de vulnerabilidades conocidas.
Paso 1 (Ejecución):	Inspeccionar dependencias y ejecutar 'pip-audit' contrastando paquetes contra la base de datos NVD.
Paso 2 (Verificación):	Documentar la lista de dependencias y registrar la ausencia de CVEs críticos.
Criterio Aceptación:	100% de dependencias fijadas y 0 vulnerabilidades críticas no mitigadas.
Evidencia / Papel:	Reporte de escaneo de dependencias pip-audit Estándar: ISO/IEC 25010
Auditoría A-15: Revisión de Estándares de Codificación PEP 8	
Objetivo:	Verificar cumplimiento de la guía de estilo oficial de Python (PEP 8) y docstrings.
Paso 1 (Ejecución):	Ejecutar Flake8 sobre módulos de la aplicación. Comprobar sangrías, naming conventions y docstrings.
Paso 2 (Verificación):	Elaborar informe de densidad de defectos de estilo y verificación de legibilidad.
Criterio Aceptación:	Cumplimiento >= 90% de reglas de estilo PEP 8.
Evidencia / Papel:	Reporte de linter Flake8 Estándar: PEP 8

Módulo 4: Fase de Despliegue y Puesta en Producción (5 Auditorías)

Auditoría A-16: Revisión del Proceso de Entrega y Empaquetado	
Objetivo:	Verificar empaquetado reproducible y control de versiones formal.
Paso 1 (Ejecución):	Inspeccionar 'wsgi.py', 'Procfile', 'vannesa.spec'. Comprobar consistencia para servidores WSGI.
Paso 2 (Verificación):	Documentar bitácora de empaquetado y prueba de ejecución limpia en entorno independiente.
Criterio Aceptación:	Proceso de despliegue 100% documentado, versionado y reproducible.
Evidencia / Papel:	Guía operativa de despliegue y Procfile Estándar: CMMI-DEV v2.0
Auditoría A-17: Revisión del Plan de Rollback y Respaldo	
Objetivo:	Verificar que el plan de rollback pueda ejecutarse en menos de 15 minutos (RTO < 15 min).
Paso 1 (Ejecución):	Ejecutar 'backup_db.py --backup' para validar respaldo con verificación de integridad. Probar 'backup_db.py --restore'.
Paso 2 (Verificación):	Registrar tiempo cronometrado de restauración y consistencia física de los datos restaurados.
Criterio Aceptación:	Tiempo de recuperación (RTO) < 15 minutos (Verificado: < 10 segundos con backup_db.py).
Evidencia / Papel:	Log de backup_db.py y verificación de integridad Estándar: ISO 22301
Auditoría A-18: Revisión de Aislamiento de Entornos de Prueba	

Objetivo:	Verificar que las pruebas unitarias operen en bases de datos temporales sin alterar producción.
Paso 1 (Ejecución):	Inspeccionar 'tests/confest.py'. Comprobar que los tests generen bases temporales independientes.
Paso 2 (Verificación):	Documentar la prueba de aislamiento confirmando que los tests no alteran 'vannesa_db.sqlite'.
Criterio Aceptación:	100% de aislamiento entre datos de pruebas y datos de producción.
Evidencia / Papel:	Evidencia de fixtures aisladas en tests/confest.py Estándar: ISO/IEC 25010

Auditoría A-19: Revisión de Variables de Entorno y Secretos (.env)

Objetivo:	Verificar que el 100% de los secretos y claves residan en variables de entorno seguras (.env).
Paso 1 (Ejecución):	Escanear código en busca de credenciales hardcodeadas. Comprobar plantilla .env.example y .gitignore.
Paso 2 (Verificación):	Generar reporte de auditoría de exclusión de secretos en el control de versiones Git.
Criterio Aceptación:	100% de secretos en variables de entorno y 0 credenciales expuestas en Git.
Evidencia / Papel:	Archivo .env.example y reporte de escaneo Estándar: Twelve-Factor App

Auditoría A-20: Revisión de Monitoreo y Logging Estructurado

Objetivo:	Verificar registro de eventos con marcas de tiempo ISO 8601 y rotación de bitácoras.
Paso 1 (Ejecución):	Inspeccionar RotatingFileHandler en 'main.py' y generación de 'logs/farmacia_vannesa.log' (5 MB).
Paso 2 (Verificación):	Capturar extracto de logs operativos con solicitudes reales, códigos HTTP y latencia.
Criterio Aceptación:	Registro estructurado de eventos con IP, tiempo de respuesta y rotación activa.
Evidencia / Papel:	Archivo 'logs/farmacia_vannesa.log' Estándar: OWASP ASVS

Módulo 5: Fase de Test y Aseguramiento de Calidad (5 Auditorías)

Auditoría A-21: Revisión de Cobertura de Requerimientos Funcionales

Objetivo:	Verificar que los requerimientos funcionales críticos cuenten con pruebas automatizadas.
Paso 1 (Ejecución):	Cruzar la matriz de trazabilidad frente a los 20 tests implementados en 'tests/'.
Paso 2 (Verificación):	Documentar índice de cobertura de requerimientos demostrando cumplimiento $\geq 90\%$.
Criterio Aceptación:	Cobertura de requerimientos funcionales críticos $\geq 90\%$.
Evidencia / Papel:	Matriz de cobertura requerimiento-prueba Estándar: ISO/IEC/IEEE 29119-2

Auditoría A-22: Revisión de Pruebas Críticas y Transaccionales

Objetivo:	Verificar que el 100% de las pruebas transaccionales críticas se aprueben satisfactoriamente.
Paso 1 (Ejecución):	Ejecutar tests transaccionales: descuento atómico de inventario, kardex y actualización de balance de caja.
Paso 2 (Verificación):	Documentar reporte de ejecución de pruebas críticas con resultado 100% PASS.
Criterio Aceptación:	100% de pruebas críticas aprobadas y 0 defectos bloqueantes.
Evidencia / Papel:	Reporte de ejecución de pruebas críticas (100% PASS) Estándar: ISO/IEC/IEEE 29119-2

Auditoría A-23: Revisión de Evidencia Técnica Verificable

Objetivo:	Verificar que el 100% de las pruebas del plan cuente con evidencia técnica objetiva.
Paso 1 (Ejecución):	Inspeccionar carpetas de evidencias, archivos JSON de /health, logs de Pytest y DDL.
Paso 2 (Verificación):	Consolidar dossier de evidencias digitales archivadas con firma del auditor responsable.
Criterio Aceptación:	100% de las pruebas sustentadas con evidencias técnicas trazables.
Evidencia / Papel:	Dossier de evidencias digitales verificables Estándar: ISO 19011:2018

Auditoría A-24: Revisión de Pruebas de Regresión y Valores Límite

Objetivo:	Verificar suite de regresión automatizada que evalúe casos de frontera (Boundary Testing).
Paso 1 (Ejecución):	Ejecutar 'test_quality_and_services.py': venta de última unidad (stock 0), sobreventa (+1), cantidades negativas.
Paso 2 (Verificación):	Registrar resultados de aserciones de valores frontera y resistencia ante entradas anómalas.
Criterio Aceptación:	Suite de regresión automatizada ejecutable en $< 10s$ con 100% PASS.
Evidencia / Papel:	Suite de pruebas de regresión y valores límite Estándar: ISO/IEC/IEEE 29119-4

Auditoría A-25: Revisión de Rendimiento y Health Check

Objetivo:	Verificar que los endpoints respondan con latencia menor a 2.0 segundos.
Paso 1 (Ejecución):	Solicitar endpoint '/health' y medir latencia. Comprobar código HTTP 200 OK y JSON con estado 'UP'.
Paso 2 (Verificación):	Documentar métricas de latencia registradas en las bitácoras estructuradas.
Criterio Aceptación:	Tiempo de respuesta < 2.0 segundos (Verificado en proyecto: 1.1 ms en /health).
Evidencia / Papel:	Registro de latencia de /health en logs estructurados Estándar: ISO/IEC 25010

6. Tabla Resumen del Programa de Trabajo (25 Auditorías)

A continuación se consolida la matriz operativa completa cruzando código de riesgo, fase del SDLC, auditoría, pasos, evidencia y responsable asignado:

Cód.	Fase SDLC	Auditoría	Procedimiento Operativo	Evidencia Principal	Formato	Responsable
R-CAL-01	1. Requerimientos	A-01: Atomicidad	Paso 1: Muestreo 5 RFs / Paso 2: Matriz atómica.	Matriz evaluación atómica	Word/PDF	Auditor Req.
R-CAL-01	1. Requerimientos	A-02: Claridad	Paso 1: Análisis léxico / Paso 2: Sin ambigüedad.	Matriz claridad léxica	Word/PDF	Auditor Req.
R-CAL-01	1. Requerimientos	A-03: Verificabilidad	Paso 1: Testabilidad / Paso 2: Ficha aserciones.	Ficha verificabilidad	Excel	Auditor QA
R-CAL-01	1. Requerimientos	A-04: Trazabilidad	Paso 1: Matriz RTM / Paso 2: Detección huérfanos.	Matriz RTM bidireccional	Excel	Auditor QA
R-CAL-01	1. Requerimientos	A-05: Norma IEEE 830	Paso 1: Checklist 8 criterios / Paso 2: Acta.	Checklist IEEE 830	PDF	Auditor QA
R-CAL-02	2. Diseño	A-06: Modelo de Datos	Paso 1: DDL 11 campos / Paso 2: 3FN e índices.	Script DDL y diccionario	SQL/PDF	Auditor Calidad
R-CAL-03	2. Diseño	A-07: Arq. Seguridad	Paso 1: Hash script / Paso 2: Middleware rutas.	Captura hash BD y código	Código/PDF	Auditor Seg.
R-CAL-02	2. Diseño	A-08: Integración Dual	Paso 1: Inyección / Paso 2: Conmutación resiliente.	Diagrama arquitectura	UML/PDF	Auditor Calidad
R-CAL-01	2. Diseño	A-09: Diseño UI/UX	Paso 1: Ergonomía POS / Paso 2: Alertas stock.	Evaluación heurística UI	PDF/Figma	Auditor Calidad
R-CAL-02	2. Diseño	A-10: Escalabilidad	Paso 1: Concurrencia ≥ 50 / Paso 2: Índices BD.	Reporte escalabilidad	PDF	Auditor Infra.
R-CAL-03	3. Construcción	A-11: Calidad Código	Paso 1: Estático Flake8 / Paso 2: Radon < 10 .	Reporte Flake8 y Radon	HTML/PDF	Auditor Calidad
R-CAL-04	3. Construcción	A-12: Tests Unitarios	Paso 1: Pytest / Paso 2: Coverage $\geq 80\%$ (84%).	Reporte Coverage 84%	HTML/PDF	Auditor QA
R-CAL-03	3. Construcción	A-13: OWASP Top 10	Paso 1: Bandit SAST / Paso 2: Queries seguras.	Reporte escáner Bandit	JSON/PDF	Auditor Seg.
R-CAL-03	3. Construcción	A-14: Dependencias	Paso 1: pip-audit CVE / Paso 2: Fijación versions.	Reporte de escaneo CVE	JSON/TXT	Auditor Seg.
R-CAL-03	3. Construcción	A-15: Estándar PEP 8	Paso 1: Linter Flake8 / Paso 2: Docstrings.	Reporte de estilo PEP 8	TXT/PDF	Auditor Calidad
R-CAL-05	4. Despliegue	A-16: Proceso Entrega	Paso 1: Empaquetado / Paso 2: Profile y wsgi.	Guía de despliegue	PDF	DevOps
R-CAL-05	4. Despliegue	A-17: Plan Rollback	Paso 1: Respaldo / Paso 2: Simulacro backup_db.	Log backup_db ($< 10s$)	Log/PDF	DevOps
R-CAL-05	4. Despliegue	A-18: Aislamiento	Paso 1: Fixtures temp / Paso 2: Cero prod touch.	Evidencia confest.py	Código	DevOps
R-CAL-03	4. Despliegue	A-19: Secretos (.env)	Paso 1: Escaneo secretos / Paso 2: .env.example.	Plantilla .env.example	Archivo	Auditor Seg.
R-CAL-05	4. Despliegue	A-20: Monitoreo/Logs	Paso 1: RotatingHandler / Paso 2: farmacia.log.	Logs farmacia_vannesa.log	Log	DevOps
R-CAL-04	5. Test	A-21: Cobertura Req.	Paso 1: Cruce RF vs Pytest / Paso 2: Aserciones.	Matriz trazabilidad	Excel	Ingeniero QA
R-CAL-04	5. Test	A-22: Pruebas Críticas	Paso 1: Transacciones / Paso 2: 100% PASS.	Reporte pruebas transacc.	HTML	Ingeniero QA
R-CAL-04	5. Test	A-23: Evidencia Técnica	Paso 1: Recopilación / Paso 2: Dossier verificado.	Carpeta evidencias	ZIP/PDF	Ingeniero QA
R-CAL-04	5. Test	A-24: Regresión/Límites	Paso 1: Boundary testing / Paso 2: Stock cero.	Suite quality_and_services	Código	Ingeniero QA
R-CAL-05	5. Test	A-25: Rendimiento	Paso 1: GET /health / Paso 2: Latencia $< 2.0s$ (1.1ms).	Logs de latencia /health	JSON/Log	Ingeniero QA

7. Calificación de Hallazgos y Formalización Institucional

- **No Conformidad Mayor (NC Mayor):** Incumplimiento crítico de integridad de stock, criptografía o caída del servicio. Requiere subsanación obligatoria previa a producción.

- **No Conformidad Menor (NC Menor):** Desviación que no compromete la operación crítica (estilo PEP 8 o cobertura levemente bajo umbral).
- **Oportunidad de Mejora (OM):** Recomendación proactiva para optimizar modularidad o rendimiento.

Por el Equipo Auditor Especialista:	Por la Dirección de Farmacia Vannesa:
Auditor Líder de Calidad de Software Certificación CISA / ISO 19011 Lead Auditor	Gerencia General / Patrocinador del Proyecto Farmacia Vannesa — Dirección Ejecutiva
<i>Fecha: Octubre 2026 Estado: Aprobado</i>	<i>Fecha: Octubre 2026 Estado: Aprobado</i>